

MUTOWA Standard 0926-PQTP

Private Quantum-Edge Telephony Protocol

Architecture, Security, Transport, Trust, Recovery, and Conformance Standard

Document status: Published standard

Design principle: *Complex underneath. Simple on top.*

Abstract

MUTOWA Standard 0926-PQTP defines an internet-native communications architecture for secure voice, video, messaging, identity, trust, distributed routing, offline operation, account recovery, emergency interoperability, and legacy telephony interconnection.

The standard separates the human-facing account address from cryptographic device identity. A MUTOWA address uses the form +CCC NNN NNN NNN; it identifies an account and does not encode a carrier, geographic region, device, or route. Device identity is represented through the MUTOWA Ephemeral Public Address (MEPA) and associated signed device state.

The security architecture combines classical and post-quantum cryptography, hardware-backed device protection where available, authenticated signaling, encrypted media, bounded operational metadata, signed revocation, threshold recovery, and explicit trust levels. The architecture also defines local ephemeral mesh behavior for disconnected environments, controlled transport fallback, federation, emergency-service profiles, legacy PSTN gateways, secure software supply-chain requirements, testing, conformance, and disaster recovery.

This standard defines normative behavior and engineering requirements. It does not assert that any particular global allocation authority, emergency regulator, carrier interconnect, implementation, certification program, or production deployment already exists. Jurisdiction-specific functions remain subject to applicable law and deployment agreements.

Conformance language

The key words **MUST**, **MUST NOT**, **REQUIRED**, **SHALL**, **SHALL NOT**, **SHOULD**, **SHOULD NOT**, **RECOMMENDED**, **MAY**, and **OPTIONAL** are to be interpreted as normative requirements.

Where this standard identifies a mechanism as a deployment profile, jurisdiction profile, or implementation option, the implementation **MUST** expose the applicable choice explicitly rather than silently substituting a weaker behavior.

1. Scope and Architectural Principles

1.1 Scope

MUTOWA defines:

- a human-facing global account namespace;
- account-to-device separation;
- cryptographic device identity;
- distributed registry and routing behavior;
- authenticated signaling;
- encrypted real-time media;
- trust levels and abuse controls;
- offline local signaling and media fallback;
- threshold account recovery;
- signed revocation;
- federation between independent operators;
- emergency-service and legacy-network profiles;
- privacy-bounded operational telemetry;
- secure software and node integrity requirements;
- conformance and interoperability testing.

The standard does not require a single physical network operator. A conforming deployment MAY be operated by one organization or by multiple federated operators.

1.2 Architectural layers

Layer	Function
4 · User Experience	Contacts, names, handles, numbers, calls, messaging, security indicators
3 · Trust	Identity, device attestation, trust levels, screening, revocation
2 · Routing & Identity	Addressing, registry, MEPA, Anycast/DHT, federation
1 · Security & Transport	Hybrid cryptography, signaling, media, NAT traversal, fallback

1.3 Core invariants

1. The public number is an **account locator**, not a device key.
2. Each device has independently revocable credentials.
3. Authenticated sessions MUST bind identity, negotiated capabilities, endpoint roles, registry state, and transport context into the authenticated transcript.
4. Fallback modes MUST NOT silently reduce the assurance level of a session.

5. Cached identity is freshness-bounded state, not permanent authority.
6. Emergency routing is an explicit jurisdiction profile.
7. Algorithm and capability negotiation **MUST** be authenticated and downgrade-resistant.
8. No single edge node **MUST** be able to unilaterally rewrite authoritative global identity state.
9. Cryptographic identity and reputation **MUST** remain separate concepts.
10. Operational telemetry **MUST** be minimized to what is required for routing, security, abuse prevention, emergency service, governance, or reliability.

1.4 User experience contract

The ordinary user **SHOULD** see a contact, number, or handle and a small set of meaningful security states such as:

- **Verified**
- **Private**
- **Legacy**
- **Limited**
- **Spam warning**
- **Emergency**

Cryptographic keys, routing, edge selection, registry synchronization, NAT traversal, and media protection **SHOULD** remain below the normal interface.

2. Threat Model and Security Objectives

2.1 Adversary classes

Threat actor	Relevant capability
Passive observer	Observes timing, sizes, endpoints, and availability
Active network attacker	Injects, modifies, reorders, delays, replays, or drops traffic
Compromised endpoint	Controls a valid device credential
Registry attacker	Attempts false mappings, stale state, or resolution failure
Sybil operator	Creates multiple infrastructure identities
Spam operator	Automates calls, rotates identities, and abuses trust
Lost-device attacker	Obtains a lost endpoint and attempts access
Malicious relay	Attempts endpoint substitution or traffic manipulation
Supply-chain attacker	Compromises software, dependencies, build infrastructure, or update channels
Governance attacker	Attempts unauthorized policy or infrastructure changes

2.2 Security objectives

A conforming implementation **MUST** be designed to provide:

- authentication of the terminating cryptographic identity;
- confidentiality and integrity of native signaling and media;
- forward secrecy for supported session constructions;
- replay resistance for control-plane transactions;
- post-compromise recovery through revocation and re-keying;
- bounded exposure when a device is lost or compromised;
- availability through distributed routing and controlled fallback;
- protection against silent algorithm downgrade;
- data minimization and bounded operational telemetry.

2.3 Non-goals

The standard does not claim:

- universal anonymity;
- perfect spam classification;
- guaranteed operation under all censorship or outage conditions;
- universal emergency-service availability;
- immunity to a fully compromised endpoint;
- that post-quantum cryptography eliminates endpoint compromise;
- that optional AI screening can make perfect security or abuse decisions.

3. Addressing, Registry, and Account Mapping

3.1 Universal account address

The human-facing format is:

+CCC NNN NNN NNN

CCC is a three-digit MUTOWA country namespace. NNN NNN NNN is the nine-digit subscriber component.

The address MUST NOT encode:

- geographic region;
- carrier;
- device;
- transport;
- routing path;
- cryptographic public key.

A deployment MAY provide human-readable handles such as @par ker . A handle MUST resolve to the same account identity model and MUST NOT bypass cryptographic verification.

3.2 Namespace properties

Each country namespace contains up to 1,000,000,000 nine-digit subscriber values. Allocation authorities MUST prevent duplicate active assignments within a namespace.

The allocation mechanism MUST be auditable and MUST support:

- assignment;
- transfer where permitted;
- suspension;
- retirement;
- recovery from administrative error;
- protection against conflicting active assignments.

3.3 Registry classes

Registry class	Purpose
Allocation	Assigns an account address to an account
Identity	Maps account state to current MEPA/device state
Revocation	Publishes authoritative invalidation state
Capability	Advertises supported cryptographic and transport profiles
Emergency	Maps jurisdiction to emergency routing behavior
Federation	Records authenticated inter-operator relationships

3.4 Resolution flow

User → Number/Name → MUTOWA Registry → MEPA → Current Device → Nearest Edge → Encrypted Session

Registry responses MUST be authenticated. They SHOULD carry an issuer identity, freshness marker, validity window, and monotonically advancing state epoch or equivalent rollback-detection mechanism.

3.5 Caching

Caches MUST be treated as bounded trust state.

A cache entry MUST have:

- an authenticated identity or cache reference;
- freshness information;
- an expiration policy;

- a binding to the account/device identity;
- a mechanism for invalidation after revocation.

A cache hit MUST NOT override a newer authoritative revocation.

4. MEPA Identity and Device Lifecycle

4.1 Core MEPA structure

The core MEPA structure is:

0x04 + Ed25519 public key (32 B) + ML-KEM-1024 public key (1568 B) + Node ID (4 B) = 1605 bytes

MEPA values are machine identities. They are not intended for ordinary users to memorize or manually enter.

4.2 Signed identity object

A signed identity object SHOULD contain:

Field	Purpose
MEPA core	Cryptographic identity material
Account ID	Binds the device to the account
Device ID	Identifies the endpoint
Key epoch	Identifies the active credential period
Capabilities	Supported protocol profiles
Validity	Creation, activation, and freshness
Issuer	Registry or authority identity
Signature	Authenticates the complete object

The complete object MUST be authenticated as one unit. Partial validation MUST NOT be treated as full identity validation.

4.3 Device state machine

PROVISIONED → ACTIVE → SUSPENDED → ACTIVE

ACTIVE → REVOKED

ACCOUNT → RECOVERY-PENDING → NEW PRIMARY ACTIVE

A replacement device is a new cryptographic credential. Reusing a previous device key without an explicit recovery ceremony is NOT permitted.

4.4 Hardware protection

Secure Enclave, StrongBox, TPM 2.0, or an equivalent hardware-backed security mechanism is RECOMMENDED.

Where hardware protection is unavailable, a software fallback MAY be used, but the resulting trust state MUST be distinguishable from hardware-backed state.

Private keys SHOULD be generated inside protected hardware and SHOULD NOT be exportable in ordinary operation.

5. Cryptographic Suite and Composition

5.1 Default cryptographic profile

Function	Standard profile
Classical key agreement	X25519
Post-quantum KEM	ML-KEM-1024
Device signature	ML-DSA-87
AEAD	AES-256-GCM or an explicitly approved equivalent
KDF	HKDF with domain separation
Hash	Approved SHA-2 family profile

5.2 Hybrid key establishment

When the hybrid profile is selected, the final session secret MUST depend on both the classical and post-quantum contributions.

The implementation MUST define and test:

- input ordering;
- domain separation;
- transcript binding;
- failure handling;
- rejection behavior;
- algorithm identifiers;
- downgrade resistance.

If either required component is absent, malformed, or fails validation, the implementation MUST NOT silently treat the session as equivalent to a fully hybrid session.

5.3 Transcript binding

The authenticated transcript SHOULD cover at minimum:

- protocol/profile identifiers;
- suite identifiers;
- account and device identities;
- registry state;
- endpoint roles;

- nonces;
- key-exchange values;
- transport mode;
- negotiated capabilities.

A relay **MUST NOT** be able to replace one endpoint, suite, transport mode, or capability set without invalidating transcript authentication.

5.4 Domain separation

Independent key uses **MUST** use independent domain labels, for example:

- PQTP-SIGNAL
- PQTP-MEDIA
- PQTP-RECOVERY
- PQTP-MIGRATION
- PQTP-CACHE

Implementations **MUST NOT** reuse a derived secret across unrelated protocol purposes without explicit domain separation.

5.5 Session key epochs

Session keys **SHOULD** be short-lived and periodically rotated. Rekeying **MUST** preserve transcript continuity and **MUST** prevent an attacker from replaying an earlier epoch.

6. Signaling Protocol and State Machine

6.1 Call states

State	Meaning
IDLE	No active attempt
RESOLVING	Identity lookup
AUTHENTICATING	Identity and device validation
NEGOTIATING	Capabilities and media parameters
ESTABLISHED	Protected session active
REKEYING	New key epoch being activated
DEGRADED	Relay, fallback, or quality adaptation
TERMINATING	Shutdown and cleanup
FAILED	Call attempt ended

Illegal state transitions **MUST** be rejected.

6.2 Message families

Message	Function
RESOLVE	Resolve a number or handle
IDENTITY	Provide signed identity or cache reference
OFFER / ANSWER	Negotiate a session
KEYCONF	Confirm transcript-derived state
REKEY	Advance key epoch
REVOKE	Publish device/account invalidation
MIGRATE	Submit account recovery transaction
EMERGENCY	Invoke emergency profile
ERROR	Return an authenticated protocol error

6.3 Transaction integrity

Control-plane transactions MUST have:

- a unique transaction identifier;
- bounded validity;
- authenticated origin;
- replay protection;
- deterministic deduplication behavior.

Migration, revocation, governance, and emergency transactions require stronger anti-replay guarantees than ordinary call offers.

6.4 Error handling

Protocol errors SHOULD reveal only the minimum information required for recovery. Authentication failures MUST NOT expose private key material, session secrets, or sensitive registry information.

7. Wire Format, Serialization, and Downgrade Resistance

7.1 Serialization

Protocol Buffers are the reference serialization approach for structured control messages.

A conforming serialization profile MUST define:

- canonical encoding;
- maximum field sizes;
- required and optional fields;

- unknown-field behavior;
- message identifiers;
- integer bounds;
- nesting and repetition limits.

7.2 Parser requirements

Implementations **MUST**:

- reject oversized messages before large allocations;
- validate lengths before copying;
- bound repeated fields and recursion;
- fuzz externally reachable decoders;
- reject malformed signatures;
- reject impossible state transitions;
- reject unsupported mandatory fields.

7.3 Profile negotiation

Negotiated cryptographic, transport, and capability profiles **MUST** be authenticated inside the session transcript.

A peer **MUST NOT** be able to force a weaker profile merely by removing stronger capabilities from an unauthenticated negotiation.

7.4 Replay protection

Control-plane messages **MUST** include a nonce, transaction identifier, monotonically advancing epoch, or an equivalent anti-replay mechanism.

Migration, revocation, governance, and emergency transactions **MUST** have explicit freshness semantics.

7.5 Algorithm agility

Algorithm identifiers are protocol data. Implementations **MUST** reject unsupported mandatory algorithms and **MUST NOT** substitute an undeclared algorithm.

8. Transport, NAT Traversal, and Media

8.1 Transport abstraction

Identity **MUST** remain independent of the underlying transport.

Conforming deployments **MAY** use:

- QUIC-based control;

- TLS-based signaling;
- encrypted edge transports;
- authenticated relays;
- direct peer-to-peer paths.

Changing transport **MUST NOT** change the account identity or trust level.

8.2 NAT traversal

Implementations **SHOULD**:

1. collect permitted local candidates;
2. obtain server-reflexive candidates through controlled infrastructure;
3. use authenticated relay candidates when direct connectivity fails;
4. prefer viable low-latency paths subject to policy;
5. re-evaluate connectivity after network changes.

8.3 Media

Native real-time media remains WebRTC/SRTP-compatible.

The media plane **MUST** be cryptographically bound to the signaling transcript so that a transport relay cannot substitute a different endpoint.

8.4 Media key epochs

Phase	Rule
Create	Derive from authenticated session state
Rotate	Advance using fresh authenticated key material
Confirm	Authenticate the new epoch
Retire	Reject traffic from expired epochs after the defined overlap window

8.5 Path migration

Path changes **MUST NOT** require a new account identity. The endpoint **SHOULD** prove continuity of the authenticated session before accepting the new path.

8.6 Stateful session caching

For validated contacts, implementations **MAY** cache authenticated identity state.

A warm-cache exchange **MAY** use a compact authenticated reference rather than retransmitting the complete identity object. A cache reference **MUST** be bound to:

- the expected account;

- the expected device;
- the relevant key epoch;
- the cached object digest;
- freshness policy.

A cache miss, stale entry, revocation, or key change **MUST** trigger full identity validation.

8.7 Stealth transport

A deployment **MAY** provide transport encapsulation to reduce protocol fingerprinting or blocking.

Stealth transport **MUST NOT** weaken cryptographic authentication. Traffic-shaping or encapsulation mechanisms are transport features, not replacements for end-to-end security.

9. Offline Local Ephemeral Mesh

9.1 Purpose

The local mesh provides bounded operation when ordinary Internet routing is unavailable.

Supported discovery mechanisms **MAY** include:

- Bluetooth Low Energy;
- Wi-Fi Direct;
- local peer discovery;
- previously authenticated local state.

9.2 Discovery

Proximity **MUST NOT** be treated as identity.

A nearby device is trusted only when its cryptographic identity and applicable trust relationship are validated.

9.3 Offline policy

Offline operation **MUST** preserve the caller's trust level.

- Verified contacts **MAY** establish a protected local session using valid cached identity state.
- Unknown callers **MUST** remain subject to the applicable untrusted policy.
- Revoked or expired identities **MUST NOT** be treated as valid solely because they are cached.
- Emergency behavior **MUST** follow the applicable emergency profile.

9.4 Local routing

A limited-hop local mesh **MAY** forward signed call offers and, where permitted, media.

Forwarding state MUST be bounded by policy so that offline operation does not silently become an uncontrolled permanent routing overlay.

9.5 Reconnection

When Internet connectivity returns:

1. authoritative registry state MUST be revalidated;
2. stale local state MUST be reconciled;
3. newly observed revocations MUST supersede cached credentials;
4. recovery and migration transactions MUST be checked for replay;
5. local-only state that cannot be validated MUST expire.

10. Account Recovery, Migration, and Revocation

10.1 Threshold recovery

The account recovery model uses an m -of- n quorum of designated trusted participants.

Shamir's Secret Sharing MAY be used to distribute recovery material, but the network MUST NOT retain a centralized master recovery seed.

10.2 Migration transaction

Element	Purpose
Account ID	Target account
Recovery epoch	Prevents replay of earlier recovery
New MEPA/device	New primary identity
Threshold policy	Defines authorized quorum
Approvals	Participant authorization set
Nonce/freshness	Prevents replay
Transaction hash	Binds complete content
Final signature set	Authorizes migration

The complete transaction MUST be hashed and signed as one authenticated object.

10.3 Recovery ceremony

A recovery ceremony MUST:

- authenticate each participant;
- enforce the configured threshold;

- reject duplicate or stale approvals;
- bind approvals to the exact target device;
- prevent replay across recovery epochs;
- produce an auditable cryptographic result;
- activate the new primary only after threshold validation.

10.4 Revocation

Revocation MAY apply to:

- a device;
- a key epoch;
- an account;
- an issuer;
- a compromised protocol profile.

Compact filters MAY accelerate revocation checks. Exact verification MUST resolve filter false positives.

10.5 Incident response

A security incident SHOULD follow:

1. signed revocation publication;
2. cache invalidation;
3. forced re-authentication where required;
4. credential rotation;
5. affected-profile isolation;
6. authenticated security advisory;
7. recovery and post-incident review.

11. Trust, Reputation, AI, and Abuse Controls

11.1 Identity versus reputation

Cryptographic identity proves control of a credential. It does not prove that a call is desirable, lawful, or non-abusive.

Reputation systems MUST NOT silently overwrite cryptographic identity.

11.2 Trust levels

Level 1 — Direct

A direct cryptographic relationship exists between the parties or their authenticated devices.

Level 2 — Trusted

Trust is established through verified relationships or configured trust anchors.

Level 3 — Zero Trust

The caller is not sufficiently trusted and receives additional controls, rate limits, screening, or challenge requirements.

11.3 AI screening

Optional edge AI MAY screen suspicious or unknown traffic.

Where confidential-compute infrastructure is used, screening SHOULD execute inside a protected environment such as an AMD SEV-SNP-class confidential-compute deployment or equivalent.

AI screening MUST NOT be inserted into the normal trusted media path unless explicitly required by policy.

Model details, thresholds, training data, and any zero-knowledge audit circuits MUST be separately specified and independently evaluated before they are treated as authoritative security mechanisms.

11.4 Micro-staking

Level 3 traffic MAY use compute-credit micro-staking as a rate-control mechanism.

Stage	Behavior
Initiation	Caller escrows a bounded compute-credit stake
Screening	Authorized node evaluates the applicable policy
Accepted	Stake is refunded
Flagged	Stake may be burned or allocated according to policy
Dispute	A defined appeal path is required

Emergency calls MUST NOT depend on staking.

Staking limits MUST prevent attackers from causing disproportionate financial or resource exposure.

12. Federation, Sunlight Nodes, and Governance

12.1 Reference topology

A reference deployment MAY use a distributed set of Anycast/Sunlight Nodes. The architecture does not require a fixed global node count.

A deployment MUST define:

- node eligibility;
- anti-Sybil controls;

- software integrity requirements;
- routing responsibilities;
- governance participation;
- failure handling;
- operator accountability.

12.2 Federation object

Field	Purpose
Operator ID	Unique infrastructure operator
Trust anchor	Authenticates operator
Capabilities	Supported profiles
Policy	Routing, privacy, and abuse policy
Region	Service jurisdiction
Interconnect	Authenticated endpoint
Status	Active, suspended, or retired

12.3 Governance

The reference governance model uses one-node-one-vote with anti-Sybil controls.

Governance MUST provide:

- authenticated proposals;
- authenticated votes;
- auditable eligibility;
- reproducible or independently verifiable builds;
- supermajority requirements for major security changes;
- an expedited but auditable emergency-security path.

12.4 Separation of duties

Identity authority, routing, abuse screening, governance, and release signing SHOULD NOT be one implicit trust domain.

Compromise of one role SHOULD NOT automatically provide authority over unrelated roles.

13. Emergency Services and Legacy Interoperability

13.1 Emergency profile

Emergency calling MUST use a dedicated jurisdiction profile.

The profile MUST define:

- emergency number recognition;
- routing;
- required metadata;
- location handling;
- fallback behavior;
- gateway behavior;
- user-facing failure states.

Emergency calls MUST bypass ordinary spam-stake requirements.

13.2 Emergency state machine

State	Behavior
DETECTED	Emergency profile recognized
ROUTING	Best route selected
LOCATION	Authorized location prepared
CONNECTED	PSAP or gateway connected
DEGRADED	Fallback or legacy route active
FAILED	Defined alternate route attempted where possible

13.3 Legacy PSTN

Dedicated gateways connect native MUTOWA sessions to legacy telephone networks.

The client SHOULD clearly indicate a legacy path without exposing gateway or signaling complexity.

13.4 Jurisdiction and lawful-interception boundary

Emergency and lawful-interception requirements are jurisdiction-specific.

A deployment MUST implement applicable legal requirements through explicit jurisdiction profiles and SHOULD avoid introducing universal master keys or a universal cryptographic backdoor.

14. Privacy, Telemetry, and Observability

14.1 Privacy budget

Every subsystem MUST document:

- what operational data it collects;

- why the data is required;
- how long it persists;
- who can access it;
- when it expires;
- how deletion or expiration is enforced.

14.2 Permitted operational purposes

Subsystem	Permitted purpose
Registry	Identity and routing freshness
Edge	Transient routing/session state
Abuse	Minimum signals for rate control
Emergency	Required service and location data
Governance	Node eligibility and vote integrity
Reliability	Aggregate health and capacity measurement

14.3 Content boundary

Native trusted calls **MUST NOT** require persistent audio/video inspection.

Optional screening applies only to defined risk profiles and **MUST** be clearly represented in policy and user-visible state.

14.4 Metrics

Implementations **SHOULD**:

- prefer aggregate counters over individual call histories;
- never log private keys or session secrets;
- use controlled debug modes;
- set explicit retention limits;
- separate security incident records from ordinary analytics.

14.5 Metadata reality

The architecture minimizes telemetry; it does not claim that operational metadata can be eliminated in every deployment.

Emergency routing, abuse prevention, routing, availability, and governance can require limited metadata.

15. Secure Software Supply Chain and Node Integrity

15.1 Software integrity

Strong cryptography cannot compensate for compromised client or node software.

A conforming deployment MUST establish a trustworthy software-release process.

15.2 Release controls

Release systems SHOULD provide:

- reproducible or deterministic builds where practical;
- signed artifacts;
- signed release manifests;
- dependency inventories;
- vulnerability monitoring;
- hardware-backed attestation where available;
- rollback protection;
- separation of release and approval authority.

15.3 Node attestation

Sunlight Nodes SHOULD expose a verifiable software/firmware identity and configuration state.

Governance eligibility MAY depend on a defined attestation policy.

15.4 Emergency update

Emergency security updates MUST be authenticated and bound to a specific release identity.

Anti-rollback controls MUST prevent attackers from silently reinstalling a known-vulnerable release.

16. Formal Verification, Testing, and Conformance

16.1 Evidence targets

Property	Evidence target
Authentication	Reviewed cryptographic composition
Confidentiality	Explicit assumptions and security analysis
Recovery	Threshold and transaction-binding analysis
State safety	Model checking or exhaustive transition review
Parser safety	Fuzzing and bounds analysis
Downgrade resistance	Adversarial negotiation tests
Revocation	Stale-state and race-condition testing
Offline safety	Cache, expiry, and reconnection tests

16.2 Required test program

A conforming implementation SHOULD maintain:

- golden serialization vectors;
- PQC and hybrid cryptographic vectors;
- malformed-input and parser fuzzing;
- replay and downgrade tests;
- NAT and relay testing;
- path migration tests;
- offline mesh testing;
- stale-state testing;
- recovery with malicious or absent participants;
- governance and Sybil testing;
- emergency gateway interoperability testing.

16.3 Conformance profiles

Profile	Minimum scope
Core	Addressing, MEPA, signaling, hybrid crypto
Media	Core + protected real-time media
Trust	Media + trust/revocation
Offline	Trust + local mesh
Recovery	Threshold migration
Federated	Multi-operator interconnect
Emergency	Jurisdiction emergency profile
Node	Routing, registry, revocation, governance, integrity

An implementation MUST declare the profiles it supports.

17. Performance, Capacity, Disaster Recovery, and Human Factors

17.1 Required measurements

Metric	Measurement
Setup time	Median and tail latency
Handshake size	Cold-cache and warm-cache bytes
CPU	Per-call cryptographic cost
Battery	Energy per call and idle impact
Packet loss	Defined loss-rate tests
Jitter	Distribution and recovery
Registry	Local, regional, and remote latency
Recovery	Time to invalidate and restore identity
Emergency	Time to select and establish best route

17.2 Failure domains

Deployments **MUST** analyze:

- single edge failure;
- regional network partition;
- registry corruption or stale replication;
- operator compromise;
- mass key compromise;
- governance signing-key compromise;
- emergency gateway outage;
- critical algorithm vulnerability.

17.3 Disaster recovery

No single node **MUST** be able to rewrite global identity state.

Recovery actions **MUST** be:

- authenticated;
- freshness-protected;
- independently verifiable;
- auditable;
- bounded by policy.

17.4 Human factors

Security indicators **MUST** correspond to exact protocol states.

Emergency calling **MUST** remain accessible.

Offline limitations **MUST** be visible.

Rate controls **MUST** minimize unnecessary exclusion of legitimate callers.

18. Reference Implementation Architecture

18.1 Client components

Component	Role
Identity manager	Device keys and account binding
Trust engine	Level 1/2/3 evaluation
Resolver	Number/handle to identity
Session engine	Handshake and key epochs
Media engine	WebRTC/SRTP
Offline engine	BLE/Wi-Fi Direct fallback
Recovery engine	Threshold migration
Emergency engine	Jurisdiction profile
Policy engine	Security, transport, and capability policy

18.2 Node components

A conforming node implementation **MAY** contain:

- Anycast ingress;
- registry resolver/cache;
- revocation service;
- relay/media support;
- Level 3 screening;
- governance participation;
- attestation/update agent;
- privacy-bounded metrics.

18.3 Implementation sequence

Implementers **SHOULD** proceed in this order:

1. threat model and security properties;

2. wire formats and state machines;
3. cryptographic composition and transcript binding;
4. interoperable client implementations;
5. device lifecycle and recovery;
6. NAT and media behavior;
7. offline behavior;
8. independent security review;
9. emergency and legacy profiles;
10. capacity and battery validation;
11. operational certification.

19. Security Considerations

MUTOWA's security model depends on correct endpoint implementation, correct cryptographic composition, trustworthy key generation, authenticated registry state, reliable revocation, and secure software distribution.

Post-quantum cryptography protects against the cryptanalytic class targeted by the selected PQC primitives; it does not protect a compromised endpoint.

Hardware-backed key storage reduces extraction risk but does not eliminate attacks against a compromised application or operating system.

Distributed governance reduces reliance on a single operator but introduces governance and Sybil risks that **MUST** be explicitly controlled.

Offline operation increases the importance of freshness and revocation semantics. Implementations **MUST** therefore prefer explicit expiration over indefinite trust in cached state.

Emergency service requires jurisdiction-specific engineering and regulatory coordination. A protocol implementation **MUST NOT** represent an emergency call as successfully connected unless the underlying route has actually been established.

20. Interoperability and Publication Requirements

A public MUTOWA implementation **SHOULD** publish:

- the normative wire schema;
- cryptographic test vectors;
- state-machine definitions;
- interoperability test cases;
- supported conformance profiles;
- security assumptions;
- threat model;
- dependency inventory;
- build and release metadata;

- documented emergency and federation profiles where applicable.

A GitHub repository SHOULD organize the standard into:

```

/
■■■ README.md
■■■ STANDARD.md
■■■ LICENSE
■■■ SECURITY.md
■■■ CONTRIBUTING.md
■■■ protocol/
■   ■■■ wire/
■   ■■■ crypto/
■   ■■■ identity/
■   ■■■ signaling/
■   ■■■ media/
■   ■■■ recovery/
■   ■■■ emergency/
■■■ conformance/
■   ■■■ vectors/
■   ■■■ interoperability/
■   ■■■ fuzz/
■■■ reference/
    ■■■ client/
    ■■■ node/

```

The standard text itself MUST remain authoritative over implementation examples.

Appendix A — Terminology

Account — The stable human-facing identity represented by a MUTOWA address.

MEPA — MUTOWA Ephemeral Public Address, the cryptographic device identity structure.

Sunlight Node — A participating MUTOWA infrastructure node providing routing, registry, governance, or related network functions.

Trust level — The policy state assigned to a relationship or caller.

Key epoch — A bounded credential or session-key period.

Registry state — Authenticated network state used to resolve account and device information.

Freshness — Evidence that an object or registry state is current within the applicable validity window.

Recovery transaction — The authenticated operation that rebinds an account to a replacement device.

Appendix B — Normative State and Transition Rules

1. IDLE → RESOLVING requires a valid call target.
2. RESOLVING → AUTHENTICATING requires an authenticated resolution result.
3. AUTHENTICATING → NEGOTIATING requires valid identity and policy checks.
4. NEGOTIATING → ESTABLISHED requires successful transcript confirmation.
5. ESTABLISHED → REKEYING occurs when policy requires a new key epoch.

6. Any state MAY transition to FAILED on an authenticated fatal error.
7. ACTIVE → REVOKED MUST be monotonic for the affected credential until a distinct recovery credential is created.
8. A cached identity MUST NOT override a newer authenticated revocation.
9. A transport change MUST NOT imply an identity change.
10. An emergency session MUST use the emergency policy even when ordinary trust or abuse controls would otherwise block the caller.

Appendix C — Cryptographic Transcript Requirements

The transcript hash MUST bind all security-relevant negotiated state.

At minimum, the transcript domain SHOULD include:

```
domain
account identity
device identity
registry state
key epoch
endpoint role
supported cryptographic profiles
selected cryptographic profile
supported transports
selected transport
nonces
classical key-exchange values
post-quantum KEM values
capabilities
emergency/trust policy state
```

The transcript MUST be authenticated before protected application data is accepted.

A transport relay MUST NOT be able to remove or replace a transcript element without causing authentication failure.

Appendix D — Recovery Ceremony Requirements

A recovery ceremony consists of:

1. creation of a recovery request;
2. authentication of the account and requesting participant;
3. collection of distinct participant approvals;
4. verification of the configured threshold;
5. verification of the recovery epoch;
6. binding to the exact replacement MEPA/device;
7. final transaction authentication;
8. publication of the resulting account state;
9. revocation or suspension of superseded credentials where required.

No participant approval may be reused across unrelated recovery transactions.

Appendix E — Conformance Checklist

An implementation claiming MUTOWA conformance SHOULD demonstrate:

- ☐ Correct +CCC NNN NNN NNN account handling
- ☐ Account/device separation
- ☐ MEPA serialization and validation
- ☐ X25519 + ML-KEM-1024 hybrid establishment
- ☐ ML-DSA-87 device authentication
- ☐ Transcript binding
- ☐ Replay protection
- ☐ Downgrade resistance
- ☐ Signed revocation
- ☐ Freshness-bounded caching
- ☐ WebRTC/SRTP-compatible media protection
- ☐ NAT traversal and authenticated relay support
- ☐ Offline local mesh behavior
- ☐ Threshold recovery
- ☐ Trust-level enforcement
- ☐ Abuse/rate-control policy
- ☐ Emergency profile implementation where applicable
- ☐ Legacy gateway signaling where applicable
- ☐ Privacy and telemetry controls
- ☐ Secure software release controls
- ☐ Parser fuzzing and interoperability testing
- ☐ Disaster recovery testing

Appendix F — Engineering Completion Criteria

A deployment is ready for operational certification only when the implementation has demonstrated:

1. interoperable wire behavior;
2. independent cryptographic review;
3. successful malformed-input and parser testing;
4. recovery and revocation correctness;
5. offline and stale-cache safety;
6. NAT, relay, and path-migration correctness;
7. measured performance and battery behavior;
8. emergency-profile interoperability where applicable;

9. secure software supply-chain controls;
10. documented operational procedures and incident response.

This standard defines the architecture and normative requirements. Deployment evidence establishes whether a particular implementation conforms to them.